

Auditing for Quality and Compliance

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 14: Monitoring and Auditing AI Systems

1. The Core Purpose of AI Auditing

AI auditing is the systematic process of evaluating an AI system's performance, fairness, data quality, and regulatory compliance. Unlike a one-time deployment review, auditing is a continuous discipline — AI models are not static software. They learn from data, and the world around them changes. A model that performed admirably at launch may quietly degrade six months later as attack patterns evolve, input distributions shift, or training data becomes stale. Auditing answers the fundamental question: Is our AI still doing what it should, in the way it should, for everyone it affects?

For security AI specifically, auditing is not optional governance overhead — it is a technical control. A threat-detection model with undetected drift, a bias toward certain network traffic profiles, or the tendency to hallucinate vulnerability details represents a direct security risk. Auditing surfaces these failures before adversaries or regulators do.

Core principle: AI auditing is quality assurance for learned behaviour, not coded logic. You cannot unit-test a neural network the way you test a deterministic function — you must audit it statistically and continuously.

2. Why AI Audits Differ from Traditional Software Audits

Traditional software audits verify that code executes as written — the logic is deterministic and explicit. AI audits verify that models behave as intended — a fundamentally harder problem because learned behaviour is implicit, emergent, and context-sensitive. This distinction reshapes both the methods and the cadence of an audit programme.

Dimension	Traditional Software Audit	AI Model Audit
What is being checked?	Code correctness vs. specification	Behaviour correctness vs. intent
Primary method	Code review, unit / integration tests	Statistical sampling, metric tracking, red-teaming
Failure mode	Bugs — discrete and reproducible	Drift, bias, hallucination — gradual and statistical
Explainability	Traceable via code path	Requires interpretability techniques (SHAP, LIME, etc.)
Cadence	On code change or release	Continuous / periodic (quarterly minimum)
Third-party risk	Library vulnerabilities	Third-party model behaviour + supply chain provenance

3. Hallucination Detection: The Silent Risk in Security AI

Large language models (LLMs) used in security workflows — for log summarisation, vulnerability triage, threat intelligence synthesis — can hallucinate: generating plausible-sounding but entirely fabricated information. An analyst trusting a hallucinated CVE description or a fictitious remediation step can introduce the very vulnerability they were trying to close.

Auditing for hallucinations requires three complementary approaches. First, fact-check model outputs against authoritative ground truth on a sampled basis — for security AI, that means NVD entries, vendor advisories, or verified threat intelligence. Second, run known-answer tests: supply the model with prompts where the correct response is already known, and measure the false-positive rate on fabricated claims. Third, instrument production systems to capture user corrections and escalations — analyst overrides of AI recommendations are a leading indicator of hallucination frequency.

Real-World Incident — Air Canada Chatbot (2024): Air Canada's LLM-powered customer service chatbot fabricated a bereavement fare policy that did not exist. A passenger relied on the hallucinated information, purchased a ticket, and was subsequently denied the discount. A tribunal ruled Air Canada responsible for its chatbot's statements. While not a cybersecurity example, this case established legal precedent that organisations are liable for AI-generated misinformation — a principle that extends directly to security AI producing false vulnerability guidance.

The implication for security AI auditors: hallucination rates must be tracked as a key performance indicator. A sustained rate above your defined threshold is grounds for model replacement, scope reduction, or mandatory human review of all outputs.

4. Accuracy Assessment: Metrics, Baselines, and Drift

Accuracy audits measure whether a model's predictive performance remains acceptable over time. The critical word is 'remains' — accuracy must be compared to a documented baseline established at deployment, not evaluated in isolation. A model scoring 91% accuracy sounds excellent; if it scored 97% at launch, the 6-point decline is a warning signal requiring investigation.

Metric	What It Measures	Security AI Relevance
Accuracy	Overall correct predictions / total	Baseline health check — declining accuracy signals drift
Precision	True positives / (True positives + False positives)	High false-positive rate burns analyst time and causes alert fatigue
Recall (Sensitivity)	True positives / (True positives + False negatives)	Low recall means real threats are missed — the critical safety metric
F1-Score	Harmonic mean of Precision and Recall	Balanced measure when both false alarms and missed threats matter
AUC-ROC	Model's ability to distinguish classes across thresholds	Threshold-independent view of classifier quality

Accuracy audits should use held-out test data that was not included in training. Reusing training data inflates performance figures and masks true generalisation ability. For high-criticality systems, hold out a rotating test set that is refreshed periodically with recent real-world examples.

5. Edge Case and Adversarial Testing

Production AI systems encounter inputs that no training set fully anticipates. Auditing on average-case inputs alone creates a false sense of robustness. Edge case testing specifically stresses the model on rare, unusual, ambiguous, and adversarially crafted inputs to reveal where the model breaks.

- Malformed or structurally unusual inputs — truncated log entries, mixed encoding, non-standard date formats — reveal parsing and preprocessing fragility.
- Novel attack signatures not yet present in training data — critical for security AI, where adversaries actively evolve techniques to evade detection.
- Adversarially crafted inputs — inputs deliberately engineered to cause misclassification, testing robustness against model evasion attacks.
- Boundary condition inputs — values at or just beyond the edges of expected distributions, such as extremely short or extremely long text payloads.
- Out-of-distribution inputs — legitimate but unusual system states that the model was not trained to handle gracefully.

An analogy: testing only on clear-day scenarios for a self-driving car. The vehicle may perform flawlessly in sunshine and fail catastrophically in fog, rain, or road construction. Security AI must be audited in the 'fog' — adversarial, ambiguous, novel conditions — because that is precisely when reliable detection matters most.

6. Bias Detection and Fairness Audits

AI models inherit statistical patterns from their training data. When that data reflects historical inequities or structural imbalances — in geographical coverage, data collection methodology, or labelling — the model replicates and often amplifies those patterns. For security AI, bias can manifest as systematically higher false-positive rates for traffic from certain network segments, geographic regions, or user populations, while simultaneously under-flagging actual threats from others.

Fairness audits extend bias detection by applying a normative standard: are outcomes equitable across groups? Disparate impact analysis compares key metrics — false positive rate, false negative rate, detection latency — broken down by meaningful subgroups. A detection model that achieves 95% recall against threats from European infrastructure but only 70% against threats from Asian infrastructure has a systemic fairness deficit that must be investigated and corrected.

Fairness Concept	Definition	Audit Method
Disparate impact	One group experiences disproportionate adverse outcomes	Compare error rates across subgroups; flag >5% differential
Equal opportunity	True positive rate is equal across groups	Break out recall by demographic / geographic segment

Calibration	Model confidence scores accurately reflect true probabilities	Plot confidence vs. actual accuracy per group
Representation	Training data covers all relevant groups proportionally	Analyse training data demographics; identify gaps

Fairness audits are simultaneously an ethical imperative and a legal requirement. GDPR Article 22 restricts fully automated decisions with significant effects on individuals; the EU AI Act requires bias evaluation for high-risk AI systems. Audit findings must be documented and remediation tracked to closure.

7. Compliance Verification

Compliance audits confirm that an AI system operates within the boundaries set by applicable regulations, frameworks, and internal policies. The specific requirements vary by industry and jurisdiction, but several themes recur across frameworks.

- **GDPR and privacy regulations:** Can the system explain decisions that affect individuals? Is personal data retained only for the required period? Are data subject rights (access, erasure) supported?
- **Financial services regulations (MiFID II, SR 11-7):** Are model governance documentation and validation records complete? Is there an independent model validation function separate from model development?
- **Healthcare AI (FDA, HIPAA):** Are model performance claims substantiated? Is protected health information handled according to required safeguards?
- **SOC 2 and ISO 27001:** Are access controls, logging, and change management processes auditable? Are audit trails complete and tamper-evident?
- **EU AI Act (high-risk AI):** Has a conformity assessment been completed? Are technical documentation and post-market monitoring systems in place?

A compliance audit is not a one-time certification exercise. Regulations evolve, AI system behaviour changes, and new use cases may bring the system into scope for requirements it previously did not trigger. Continuous compliance monitoring, integrated with the broader audit programme, is the only sustainable approach.

8. Explainability Audits

Explainability auditing verifies that the AI system's decisions can be articulated in terms a human reviewer can understand, evaluate, and act upon. This is distinct from the technical capability of interpretability — you may be able to extract feature importance scores, but if those scores do not translate into actionable analyst guidance, the explainability requirement is not met.

The audit process: select a stratified random sample of recent predictions, including both correct and incorrect classifications. Attempt to reconstruct the reasoning behind each prediction using the available explanation mechanism (SHAP values, LIME approximations, attention weights, or rule-based post-hoc explanations). Evaluate whether the explanation accurately reflects the model's true decision factors and whether the guidance is specific enough to be useful.

Auditor's test: If a junior analyst, given only the explanation output, cannot correctly reproduce the action the AI recommended and understand why — the explanation has failed its purpose. Explainability audits validate the utility of explanations, not merely their existence.

9. Data Quality and Model Drift Audits

Two of the most common root causes of AI performance degradation — poor data quality and model drift — require dedicated audit tracks.

Data quality audits examine both training data and inference-time input data. For training data: are records accurate and up to date? Are there missing values, corrupted entries, or mislabelled examples? Is the class balance appropriate for the task? For inference data: are inputs within the expected distribution? Are there anomalous spikes in missing fields or format violations that indicate an upstream data pipeline problem?

Model drift audits track performance metrics over time against the deployment baseline. There are two distinct types of drift to monitor. Concept drift occurs when the statistical relationship between inputs and outputs changes — for example, a new category of network attack that the model has never seen behaves differently from all patterns in its training data. Data drift (or covariate shift) occurs when the distribution of inputs changes, even if the underlying relationships do not — for example, a change in network infrastructure that alters the baseline traffic profile. Both types require different remediation strategies: concept drift typically requires retraining with new labelled data; data drift may be addressable through recalibration or feature engineering.

Drift Type	Root Cause	Detection Signal	Remediation
Concept drift	The world has changed — new attack patterns, new fraud techniques	Declining recall; increase in analyst overrides	Retrain on fresh labelled examples
Data drift (covariate shift)	Input distribution has changed — new infrastructure, user behaviour	Distribution shift in input features; confidence score changes	Recalibrate; update feature normalisation
Label drift	Ground truth definition has changed — regulatory or policy update	Sudden accuracy change despite stable inputs	Re-label historical data; retrain

10. Access, Authorization, and Third-Party Audits

AI systems handle sensitive data and generate outputs that influence consequential decisions. Access audits confirm that the principle of least privilege is enforced throughout the system's data access, model management, and output consumption layers.

- Review access logs for the model serving infrastructure, training data stores, and audit trail repositories — flag access by accounts with no business justification.

- Audit role assignments quarterly: remove permissions no longer required, and escalate any service account with broader access than its documented function requires.
- Examine API gateway logs for unusual query patterns — excessively high query volumes, unusual off-hours access, or repeated boundary-probing queries may indicate model extraction attacks.
- **Third-party AI components:** Audit third-party and open-source models against the same standards applied to in-house models. A vendor's model that performs as advertised in controlled benchmarks may behave differently on your production data distribution.
- **Supply chain integrity:** Verify the provenance and integrity of model weights, dependency libraries, and training datasets sourced externally. Malicious tampering with open-source model weights is an established threat vector.

11. Audit Documentation and Reporting

An audit programme without systematic documentation provides limited governance value and zero defensibility to external scrutiny. Documentation serves four purposes: it proves due diligence to regulators; it enables trend analysis over time; it creates accountability for remediation; and it provides institutional memory when personnel change.

Each audit cycle should produce a structured report containing: the audit scope, period, and methodology; the metrics measured and their comparison to baseline; findings categorised by severity (critical, high, medium, informational); recommended remediations with responsible owners and target dates; and a sign-off record. Findings must be tracked in a remediation register with status updates at each subsequent audit. Audits where high-severity findings are closed before the next cycle demonstrate a functioning governance programme; audits where the same findings recur across cycles indicate a broken remediation process.

Real-World Incident — Uber (2022 FTC Consent Order): Following a series of privacy and algorithmic accountability failures, Uber was required by the FTC to implement a comprehensive AI governance and audit programme. The consent order specifically mandated documentation of AI model performance, fairness metrics, and third-party audits by independent assessors. The case illustrates that inadequate AI audit documentation — not just poor AI behaviour — can itself be the subject of regulatory enforcement action.

Key Terms Glossary

Term	Definition
Model drift	Degradation of model performance over time as real-world conditions change; includes concept drift and data drift.
Hallucination	When an LLM generates plausible-sounding but factually incorrect or fabricated information.
Disparate impact	A statistical disparity in outcomes (e.g., false positive rates) between demographic or operational subgroups.
Fairness audit	A structured evaluation that measures whether an AI model's outcomes are equitable across relevant groups.

Explainability audit	Verification that the AI system's decisions can be articulated in actionable, human-understandable terms.
Data drift (covariate shift)	A change in the distribution of input features, independent of any change in the underlying decision function.
Concept drift	A change in the statistical relationship between inputs and outputs, typically caused by real-world changes in the environment.
F1-score	Harmonic mean of precision and recall; a balanced accuracy metric for classification tasks.
Held-out test set	A dataset excluded from model training, used exclusively for unbiased performance evaluation.
Compliance audit	A structured assessment confirming that an AI system meets the requirements of applicable regulations and internal policies.
Access audit	A review of who has access to AI system components, data stores, and outputs, verifying least-privilege adherence.
Supply chain integrity	Verification that third-party model weights, libraries, and datasets have not been tampered with.

Quick Revision Checklist

- AI audits examine learned behaviour, not coded logic — statistical and exploratory in nature.
- Hallucination detection: fact-check against ground truth, run known-answer tests, track analyst override rates.
- Accuracy metrics: track precision, recall, F1, and AUC-ROC against a documented deployment baseline.
- Edge case testing: stress the model on adversarial, malformed, novel, and boundary inputs.
- Bias detection: compare error rates across subgroups; fairness audits apply a normative standard of equitable outcomes.
- Compliance audits: verify GDPR explainability, data retention, documentation completeness, and framework-specific requirements.
- Explainability audits: validate that explanations are actionable, not merely technically present.
- Data quality audits: examine training data accuracy, freshness, and class balance; monitor inference-time input distributions.
- Drift audits: distinguish concept drift (retrain) from data drift (recalibrate); monitor quarterly minimum, monthly for security AI.
- Access audits: enforce least privilege; audit API query logs for model extraction indicators.
- Third-party audits: apply the same rigour to vendor and open-source models as to in-house models.
- Documentation: every audit cycle produces a structured report; findings tracked in a remediation register.
- Audit cadence: quarterly minimum for standard systems; monthly for critical or rapidly evolving security AI.

10 Exam-Based MCQs — AI Auditing for Quality and Compliance

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: Priya is a security AI auditor at a financial institution. The threat-detection model deployed nine months ago has been flagging significantly fewer alerts over the past three weeks compared to the monthly average from the first six months post-deployment. The threat landscape has not materially changed. Priya suspects model drift but has not yet confirmed it. What should she prioritise FIRST?

- A) Retraining the model immediately using the most recent six months of network traffic.
- B) Establishing performance metric baselines from the model's deployment period before investigating further.
- C) Disabling the model and reverting to rule-based detection until the issue is resolved.
- D) Expanding the model's training data to include data from additional geographic regions.

Answer: B **Explanation:** B is correct because without a documented baseline from deployment, there is no objective reference point against which to measure whether current performance represents a genuine decline. Baselining is the prerequisite step for drift investigation. A is wrong because retraining before diagnosing the root cause may compound the problem — if the issue is data quality or feature drift rather than a training data gap, retraining without addressing the root cause will not solve it. C is wrong because disabling the model is a disproportionate response at this stage; investigation must precede remediation decisions. D is wrong because expanding geographic coverage is a hypothesis, not a diagnosis — it should not be attempted before understanding whether the performance change is real and what is causing it.

Q2. Scenario: Marcus is reviewing the quarterly audit results for his organisation's AI-based intrusion detection system. The audit reveals that the model correctly identifies 94% of confirmed threats originating from North American IP address ranges but only 61% of confirmed threats from Southeast Asian IP ranges — even when the attack techniques are identical. His organisation serves customers globally. Which audit dimension should he investigate FIRST?

- A) Explainability — determine whether the model's decision rationale is clear to analysts.
- B) Fairness — analyse whether the model's false-negative rate differs systematically across geographic regions.
- C) Compliance — verify whether the model's use of geolocation data complies with GDPR.
- D) Data quality — audit the currency and accuracy of the threat intelligence feeds used in training.

Answer: B **Explanation:** B is correct because the described symptom — systematically missing threats from specific regions while detecting the same threat categories from others — is a direct indicator of a fairness deficit (disparate impact). Bias and fairness analysis is the logically primary investigation given the pattern described. A is wrong because explainability is relevant to understanding individual decisions, not to diagnosing systematic geographic performance disparities. C is wrong because compliance with GDPR for geolocation data is a separate concern; while important, it does not explain the performance disparity and is not the first investigative step. D is wrong because data quality is a plausible contributing factor but is a hypothesis — fairness analysis first identifies whether the disparity exists and quantifies it; data quality audits then investigate potential causes.

Q3. Scenario: An LLM-based threat intelligence tool used by a SOC team produces a detailed report citing a specific CVE number and recommending immediate patching of a particular system. An analyst, following the organisation's hallucination-awareness protocol, attempts to verify the CVE in the NIST NVD and cannot find any record of it. The model's confidence score for the output was 0.92. What is the MOST appropriate immediate action?

- A) Flag the output as potentially unreliable and escalate to a human analyst for verification before any action is taken.
- B) Discard the output and query a different AI model for a second opinion.
- C) Accept the output, as the confidence score is within normal parameters.
- D) Report the hallucination to the model vendor and await their confirmation before acting.

Answer: A **Explanation:** A is correct because the operationally safe and procedurally sound response to a potential hallucination is human escalation with a hold on automated action — not discarding the alert entirely. The underlying threat may be genuine even if the CVE reference is fabricated. B is wrong because discarding the output risks missing a real threat; querying a second model without escalating introduces delay and does not address the immediate risk. C is wrong because confidence scores measure the model's self-assessed certainty, not factual accuracy — high confidence in a hallucination is common and is itself a documented risk of LLMs. D is wrong because waiting for vendor confirmation before acting on a potential security incident is operationally unacceptable; the correct action is internal human review, not external validation.

Q4. Which term describes the situation where a model's performance declines because the statistical relationship between inputs and outputs has changed — for example, because adversaries have adopted new attack techniques the model was not trained on?

- A) Data drift
- B) Label drift
- C) Concept drift
- D) Covariate shift

Answer: C **Explanation:** C is correct. Concept drift refers specifically to a change in the underlying relationship between inputs and the target variable — new attack techniques alter what 'malicious' looks like at a feature level, degrading the model's learned decision boundary. A is wrong because data drift (also called covariate shift) refers to a change in the distribution of input features, not the input-output relationship — input data looks different, but the model's learned rules would still be valid if it could generalise. B is wrong because label drift refers to a change in the definition of ground truth labels (for example, a regulatory redefinition of what constitutes a breach) rather than a change in real-world attack patterns. D is wrong — covariate shift is a synonym for data drift, not concept drift.

Q5. What does the F1-score measure, and why is it particularly valuable for security AI classifiers?

- A) The overall percentage of predictions that are correct; valuable because it gives a single intuitive measure of model quality.
- B) The harmonic mean of precision and recall; valuable because it balances the cost of false alarms against the cost of missed threats.

- C) The true negative rate; valuable because security AI must avoid flagging legitimate traffic.
- D) The area under the ROC curve; valuable because it evaluates model performance across all classification thresholds.

Answer: B **Explanation:** B is correct. F1-score is the harmonic mean of precision and recall. For security AI, both false positives (false alarms that cause analyst fatigue and distrust) and false negatives (missed threats) carry significant operational costs. F1 provides a single metric that penalises models that maximise one at the expense of the other. A is wrong — A describes overall accuracy, which can be misleadingly high when class imbalance is severe (a model that classifies every event as benign will have high accuracy if 99% of events are benign, while having a recall of zero). C is wrong — the true negative rate is specificity, a separate metric not equivalent to F1. D is wrong — D describes AUC-ROC, a distinct metric that evaluates threshold-independent discrimination ability.

Q6. During a compliance audit for a financial services AI system that makes credit decisions, the auditor finds that the model cannot generate explanations for individual decisions in terms a customer could understand. Which regulatory concern is MOST directly implicated?

- A) SOC 2 Type II — the system lacks sufficient audit trail documentation.
- B) GDPR Article 22 — the right to an explanation for automated decisions with significant effects.
- C) ISO 27001 — insufficient access controls on the model serving infrastructure.
- D) PCI DSS — the model processes cardholder data without adequate encryption.

Answer: B **Explanation:** B is correct. GDPR Article 22 grants individuals the right not to be subject to solely automated decisions that produce significant effects, and where such decisions are permitted, organisations must be able to provide meaningful explanations. A credit decision is a textbook 'significant effect' and the inability to explain it is a direct GDPR violation. A is wrong because SOC 2 Type II addresses operational controls and audit trails for service organisations — not the explainability of individual AI decisions. C is wrong because ISO 27001 governs information security management, including access controls, but does not mandate AI explainability. D is wrong because PCI DSS governs the security of payment card data; while relevant to systems that process card information, it does not address model explainability requirements.

Q7. What is the PRIMARY purpose of using held-out test data in AI accuracy audits, rather than evaluating the model on its own training data?

- A) Held-out data is more recent and therefore more representative of current threat patterns.
- B) Held-out data prevents overfitting during the audit process itself.
- C) Held-out data provides an unbiased estimate of the model's generalisation ability, uncontaminated by training optimisation.
- D) Held-out data is required by most compliance frameworks as a condition of audit validity.

Answer: C **Explanation:** C is correct. A model evaluated on its own training data will almost always appear to perform better than it does in production — it has effectively 'memorised' the training examples. Held-out data provides an independent, unbiased estimate of how the model generalises to unseen inputs, which is what matters in production. A is wrong because held-out data is not necessarily more recent — it is simply data excluded from training regardless of its temporal position; the recency argument describes a

different best practice (temporal validation). B is wrong because overfitting is a training-time concern; the audit itself does not train the model. D is wrong because while some frameworks recommend held-out validation, the primary reason for using it is statistical validity, not compliance.

Q8. An auditor discovers that a third-party vendor's AI model, integrated into the organisation's security operations platform, was trained on a dataset that significantly underrepresents network traffic from the organisation's primary cloud environments. Which audit type would MOST directly identify and quantify this problem?

- A) Compliance verification audit
- B) Explainability audit
- C) Data quality and representation audit
- D) Access and authorization audit

Answer: C **Explanation:** C is correct. A data quality and representation audit examines whether training data covers all relevant subgroups and environments proportionally. Underrepresentation of the organisation's cloud environment in training data is precisely the type of gap this audit type is designed to surface and quantify. A is wrong because compliance verification focuses on regulatory adherence, not on the statistical composition of training data. B is wrong because explainability audits assess whether individual model decisions can be articulated — they do not diagnose training data representational gaps. D is wrong because access audits review who can access AI systems and data — they do not evaluate training data composition.

Q9. Which of the following BEST describes the concept of 'disparate impact' in the context of a fairness audit for a security AI model?

- A) The model produces inconsistent outputs for identical inputs submitted at different times.
- B) One user group experiences disproportionately higher false-positive rates than another group, despite similar actual risk profiles.
- C) The model's aggregate accuracy metric falls below the defined threshold for acceptable performance.
- D) The model assigns systematically lower confidence scores to inputs from a specific network segment.

Answer: B **Explanation:** B is correct. Disparate impact refers to a statistically significant difference in outcomes — such as false positive rates, false negative rates, or detection latency — between distinct groups, where the groups have similar underlying risk profiles. In security AI, this could manifest as analysts from one business unit facing disproportionately more false alarms than analysts from another. A is wrong because inconsistent outputs for identical inputs describes a reproducibility or stability problem, not a fairness issue. C is wrong because overall accuracy falling below a threshold describes a performance audit finding, not a fairness finding — fairness requires subgroup comparison, not aggregate measurement. D is wrong because lower confidence scores alone do not constitute disparate impact; the fairness concern arises from differences in decision outcomes (errors, alerts, classifications), not from differences in internal model confidence scores.

Q10. When an AI audit uncovers the same high-severity finding in three consecutive quarterly audit cycles, what does this MOST likely indicate?

- A) The audit methodology is incorrectly flagging a non-issue as a finding.
- B) The finding is an inherent characteristic of AI systems that cannot be remediated.
- C) The organisation's remediation tracking and accountability processes have broken down.
- D) The model requires complete replacement rather than incremental improvement.

Answer: C **Explanation:** C is correct. A recurring high-severity finding across three audit cycles is a strong indicator that the remediation process — not the detection capability — is failing. Either the finding is not being assigned a responsible owner, the remediation plan is inadequate, or accountability for closure is not being enforced. D is wrong because model replacement may or may not be the right remediation, but it cannot be concluded from recurring findings alone — the root cause of recurrence is process failure, not necessarily an unfixable technical issue. A is wrong because if the same finding recurs with consistent evidence across three independent audit cycles, methodological false-positives are highly unlikely; this would require systematic auditor error across multiple reviews. B is wrong because AI audit findings are generally addressable — bias can be mitigated, drift can be corrected, documentation can be completed; the claim that a finding is irremediable must be substantiated, not assumed.